

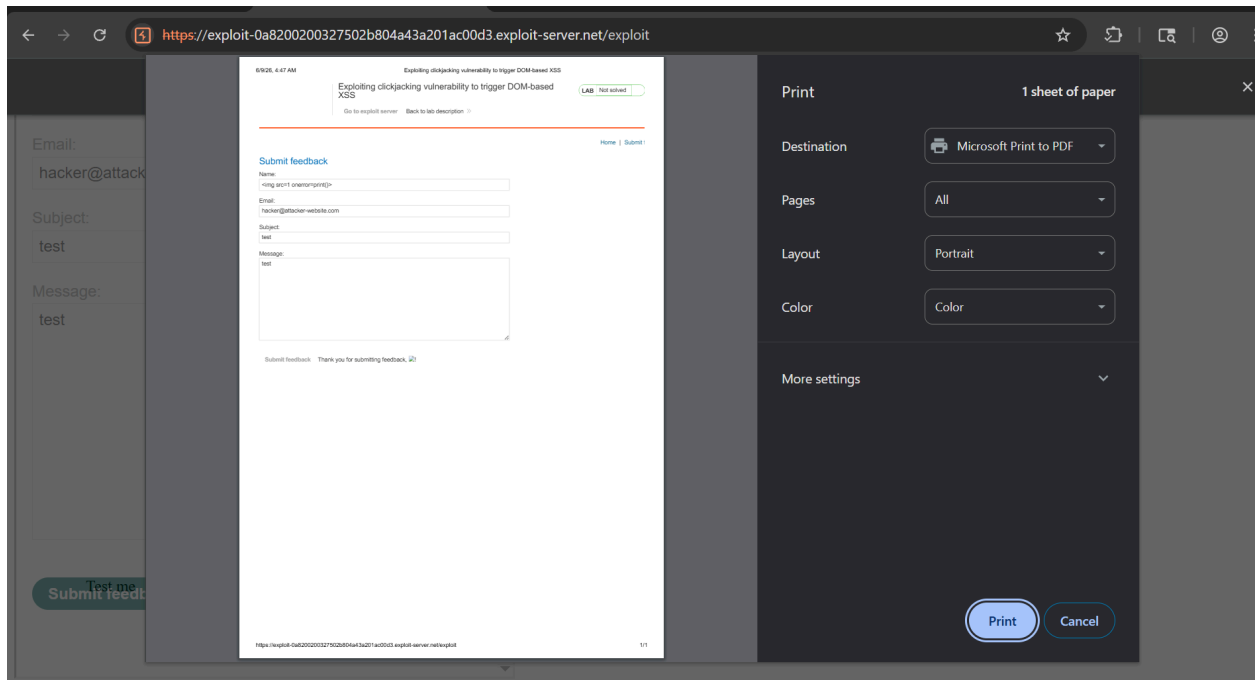
Clickjacking

Lab: Exploiting clickjacking vulnerability to trigger DOM-based XSS

Cilj zadatka: konstruisati Clickjacking napad koji navodi korisnika da klikne na naizgled bezopasno dugme, čime se u pozadini aktivira skrivena DOM-based XSS ranjivost i izvršava funkcija `print()`. Ranjivost: Aplikacija ne koristi zaštitna zaglavlja (poput `X-Frame-Options` ili adekvatnih `Content-Security-Policy` direktiva) koja bi sprečila njeno učitavanje unutar eksternih `iframe` elemenata. To omogućava napadaču da je vizuelno sakrije (pomoću `opacity: 0`) i prekrije sopstvenim, lažnim sadržajem (decoy).

Postupak rešavanja:

1. U sekciji Body na exploit serveru implementirati HTML strukturu koja sadrži lažni element za navođenje (`<div>Test me</div>`) i skriveni `<iframe>` koji učitava pripremljeni maliciozni URL
2. Privremeno podesiti `opacity: 0.5` za `iframe` element, kako bi i legitimna forma i lažni tekst bili istovremeno vidljivi radi lakšeg pozicioniranja
3. Klikom na View exploit i podešavanjem vrednosti `top` i `left` precizno pomeriti tekst "Test me" tako da se poklapa sa skrivenim dugmetom "Submit feedback"
4. Uspešno poravnanje verifikovati promenom kursora u oblik šake prelaskom preko teksta "Test me" i otvaranjem `print` forme nakon klika



5. Vratiti se na exploit server i promeniti tekst iz "Test me" u "Click me"
6. Postaviti opacity na 0.001
7. Sačuvati izmene klikom na Store , a potom kliknuti na Deliver exploit to victim, čime je zadatak uspešno rešen

